CorpLink PHP Lab

Challenge 02 — Command Injection

PHP EXPLOITATION · XE107-M04 · CYBERIUM ARENA

Questions: 10 · Topic: Command Injection → RCE

QUESTION 01 RECONNAISSANCE

Extract the lab zip using the password `infected` and start it by running `bash start.sh` inside the extracted folder. Open your browser and navigate to `http://localhost:8080`. What is the title shown on the Challenge 02 card?

HOW TO SOLVE

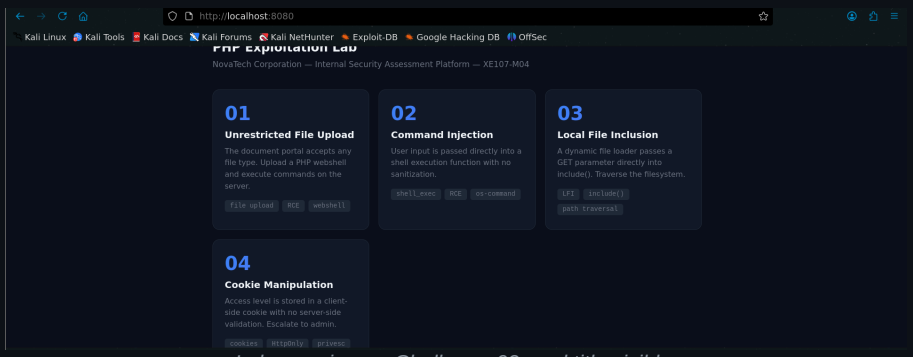
01 Extract the zip file using the password `infected`.

02 Navigate into the extracted folder and run `bash start.sh` to start the lab.

03 Open your browser and go to `http://localhost:8080`.

04 Find the Challenge 02 card on the overview page and read its title.

SCREENSHOTS



Lab overview — Challenge 02 card title visible.

ANSWER

Command Injection

QUESTION 02 RECONNAISSANCE

Navigate to Challenge 02. The tool has a hostname input field with a hint shown below it. What is the name of the Linux command the tool executes?

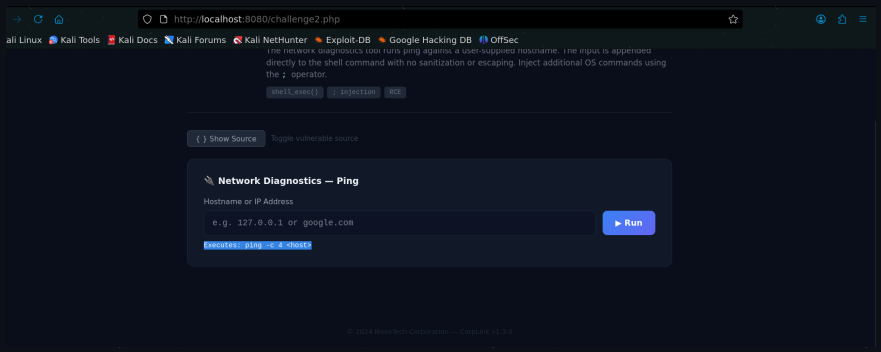
HOW TO SOLVE

01 Click on Challenge 02 in the navigation or on the overview card.

02 Look at the input field and read the hint text shown below it.

03 The hint reveals the full command the server runs — identify just the command name.

SCREENSHOTS



Challenge 02 — ping tool with hint showing the executed command.

ANSWER

ping

QUESTION 03 SOURCE CODE ANALYSIS

Click the { } Show Source button on Challenge 02. What PHP function is used to execute the shell command?

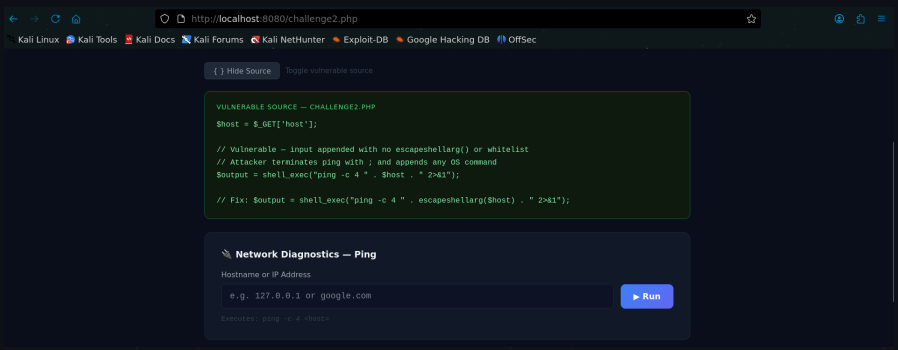
HOW TO SOLVE

01 Click the { } Show Source button at the top of the page.

02 Read the vulnerable source code that appears.

03 Find the PHP function responsible for running the shell command.

SCREENSHOTS



Source code panel — the vulnerable PHP function is clearly visible.

ANSWER

shell_exec

QUESTION 04 SOURCE CODE ANALYSIS

Looking at the source code, the user input is appended directly to the ping command with no sanitisation. What character can you add after a valid IP address to chain and run a second command?

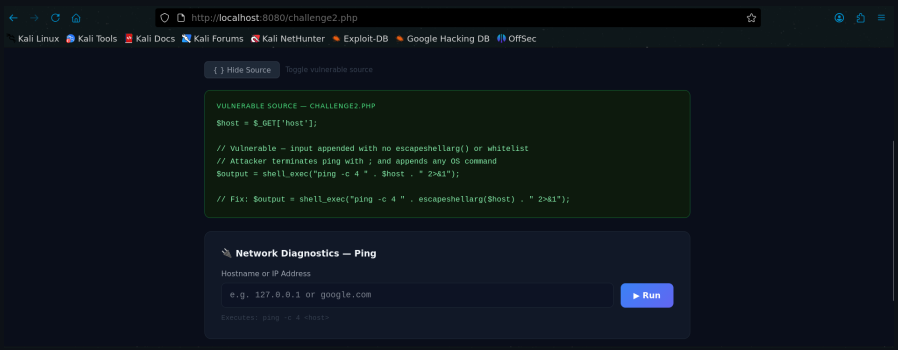
HOW TO SOLVE

01 Look at the source code still open from Q3.

02 The comment explains how an attacker terminates the ping command.

03 Find the single character used to separate and chain OS commands in a shell.

SCREENSHOTS



Source code — comment explains how the injection works.

ANSWER

;

QUESTION 05 EXPLOITATION

Enter a valid IP address in the hostname field followed by ; and a command that reveals the Linux user the web server is running as. What is the username shown in the output?

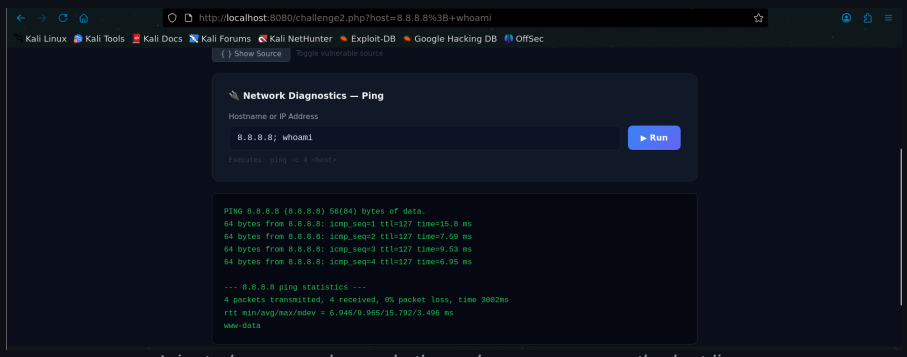
HOW TO SOLVE

01 In the hostname field, type a valid IP address followed by ; and a Linux command that shows the current user.

02 Click Run — the ping fires first, then your injected command executes.

03 The username appears on the last line of the output.

SCREENSHOTS



Injected command reveals the web server user on the last line.

ANSWER

www-data

QUESTION 06 EXPLOITATION

Use the same injection technique to find the working directory of the web server. What is the full path?

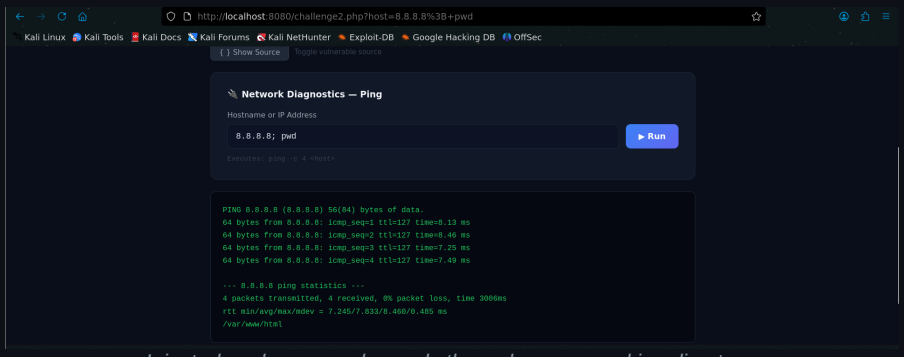
HOW TO SOLVE

01 Use the same ; injection technique from Q5.

02 Think of a Linux command that prints the current working directory.

03 The full path appears on the last line of the output.

SCREENSHOTS



Injected pwd command reveals the web server working directory.

ANSWER

/var/www/html

QUESTION 07 EXPLOITATION

Use command injection to read the contents of `/etc/passwd`. What is the username on the very first line of the file?

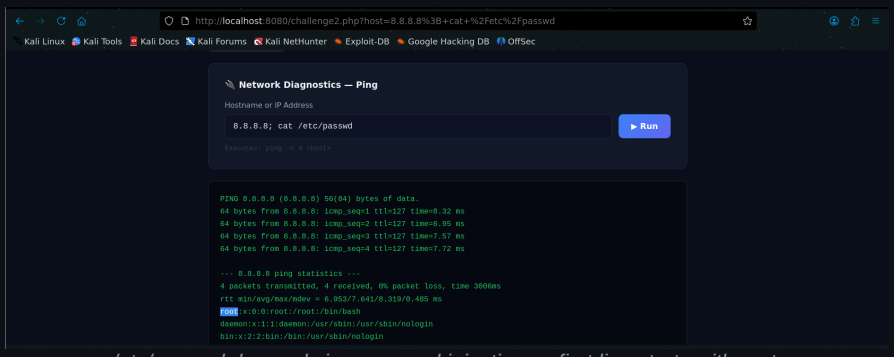
HOW TO SOLVE

01 Use the `;` injection technique to run a command that reads `/etc/passwd`.

02 The file contents appear after the ping statistics.

03 Read the very first line — the username is the text before the first colon.

SCREENSHOTS



/etc/passwd dumped via command injection — first line starts with root.

ANSWER

root

QUESTION 08 EXPLOITATION

Use command injection to find the full path of the `curl` binary installed on the server. What is the path?

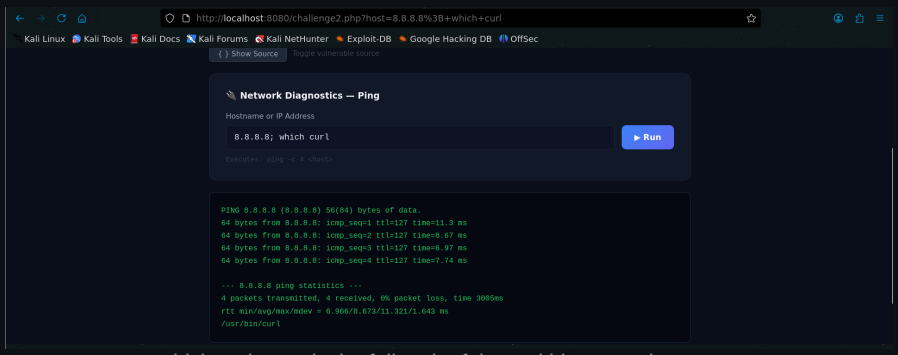
HOW TO SOLVE

01 Use the ; injection technique with a Linux command that locates installed binaries.

02 The full path of the binary appears on the last line of the output.

03 Attackers enumerate available tools on a server to plan further attacks.

SCREENSHOTS



which curl reveals the full path of the curl binary on the server.

ANSWER

/usr/bin/curl

QUESTION 09 EXPLOITATION

Use command injection to read the file `/etc/apache2/ports.conf`. What port number does Apache listen on inside the container?

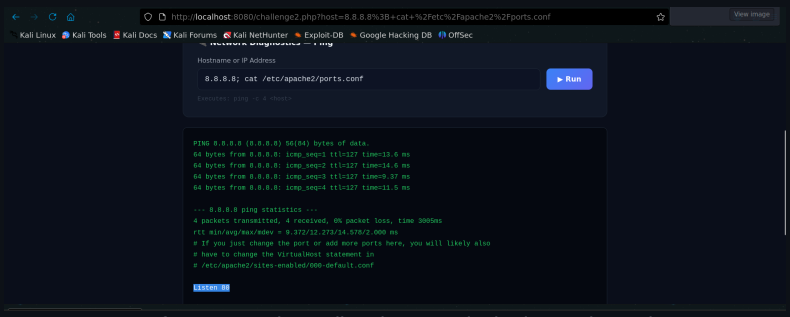
HOW TO SOLVE

01 Use the `;` injection technique to read `/etc/apache2/ports.conf`.

02 Look for the `Listen` directive in the output.

03 Note: this is the internal container port — different from the `8080` port you connect to from your browser.

SCREENSHOTS



ports.conf output — Listen directive reveals the internal Apache port.

ANSWER

80

QUESTION 10 MITIGATION

The vulnerability exists because user input is passed directly into a shell command with no sanitisation. According to the source code, what PHP function would fix this?

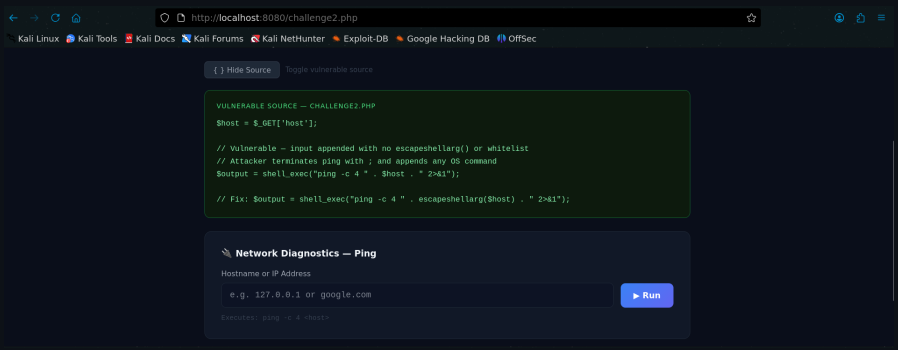
HOW TO SOLVE

01 Click `{ } Show Source` and look at the fix shown in the comment at the bottom.

02 The secure version wraps the user input with a PHP function before it touches the shell.

03 This function escapes any special characters — semicolons, pipes, ampersands — so they cannot be interpreted as shell operators.

SCREENSHOTS



Source code — the fix is shown in the comment at the bottom.

ANSWER

escapeshellarg()